

## **Security Policy Roadmap – Comprehension and Application**

Melvin Viado

Cybersecurity, Durham College

MGMT 1100: Business Process and Security Policy

Danny Aniag

October 13, 2025

## Contents

|                                                                                                  |   |
|--------------------------------------------------------------------------------------------------|---|
| Summarize Key Concepts .....                                                                     | 3 |
| Security Policy Life Cycle .....                                                                 | 3 |
| ISO/IEC 17799 (27001/27002) Framework .....                                                      | 3 |
| Risk Assessment and Controls .....                                                               | 4 |
| Answer Comprehension Questions .....                                                             | 5 |
| Importance of Aligning Security Policies with Business Objectives and Organizational Goals ..... | 5 |
| How the Document Recommends Identifying and Prioritizing Assets with an Organization .....       | 5 |
| The Role that Stakeholders Play in the Security Policy Development Process .....                 | 5 |
| Importance of Continuous Monitoring in Maintaining an Effective Security Policy .....            | 5 |
| Apply the Security Policy Roadmap to a Scenario .....                                            | 6 |
| Asset Identification .....                                                                       | 6 |
| Threat and Vulnerability Analysis .....                                                          | 6 |
| Control Selection .....                                                                          | 7 |
| Communication and Implementation .....                                                           | 7 |
| Reflect on the Policy Development Process .....                                                  | 8 |

## **Summarize Key Concepts**

### **Security Policy Life Cycle**

The process of creating a policy involves the policy life cycle. The policy life cycle includes the tasks of policy development, publication, adoption, and review, and the success of a policy depends on how an organization approaches these tasks. In an organization, the responsibilities of the policy life cycle are split between different positions of the organization. For example, the board of directors will be responsible for communication of guiding principles in the development phase, and the compliance officer will be responsible for evaluating the policy in the adoption phase.

In the development phase, the key tasks involve planning, researching, writing, vetting, approving, and authorizing. The planning task identifies the need and context of the policy and provides the reason for creation. Research defines the requirements of operations, regulations, and contracts. The writing tasks considers the intended audience and to identify and understand them because language is an important factor to gaining acceptance and resulting in success. The vetting task requires consultation of comprehensive experts for the authors. The approval task involves having all affected departments to influence and included in the policy before it is authorized for inclusive purposes and to support the cause of the policy. The authorizing task requires executives or of equal persons to agree to the policy.

Publication comes after the successful authorization in the development phase. Communication, dissemination, and education are the three tasks in the publication phase. The communication task is to tell the organization that the policy is important. Leadership is required in this task, and leaders either see it as a responsibility or a privilege. Disseminating makes the policy available and accessible. Education involves training, reinforcing understanding, raising awareness, and making connections.

Adoption aims to make the policy a normative integration, which means that the policy is expected behavior. The tasks for adoption are implementation, monitoring, and enforcement. Implementation ensures the policy is understood by all, resources are assigned, and all relevant personnel are informed. Monitoring means tracking the effectiveness of the policy. Lastly, enforcement

Review has key tasks of feedback and reauthorizing or retiring the policy. Feedback should be solicited internally and externally, and it makes sure that the policy is up to date. Outdated policies should be retired or reviewed and reauthorized.

### **ISO/IEC 17799 (27001/27002) Framework**

The ISO framework is a set of recommendations and best practices of information security. It is used as a reference for controls used in industry and commerce for all organization sizes. It is the responsibility of the organization for enforce these controls based on their specific requirements. The domains of this framework include information security policies, organization, human resources, asset management, access control, cryptography, physical and environmental security, operations, communications, systems, supplier, incident management, business continuity, and compliance. The framework helps in policy creation as it provides structure and organizes our approach for development.

## **Risk Assessment and Controls**

The risk assessment process is identifying inherent risk (depending on the threats, threat sources, and vulnerabilities), finding out impact of threat, knowing the harm of a successful threat, and calculating the chance of the threat happening. To evaluate a threat is to identify the magnitude of harm it can do and the probability that the threat can exploit a vulnerability. A control is a security measure to prevent, deter, or response to a threat source, and to determine the appropriate controls depends on the information system and its vulnerabilities. Some examples of controls would be data access, data encryption, intrusion detection systems, and more. The importance of cost-effective controls is to ensure that critical infrastructure is protected without using too many resources or allocating a great amount of budget to manage risks.

## **Answer Comprehension Questions**

### **Importance of Aligning Security Policies with Business Objectives and Organizational Goals**

Business objectives and organizational goals aligning with the security policies is important to enable the goals of the business rather than to hinder it. A proper security policy will prioritize protection for important assets while dealing with threats that could disrupt strategic goals. Therefore, the policy will also have better risk management by directing resources to deal with threats that would have the most significant impact to core operations and financial position of the organization.

### **How the Document Recommends Identifying and Prioritizing Assets with an Organization**

The document recommends listing the assets used by critical processes, including physical assets, and quantifying their importance by applying a value to those assets which helps us prioritize the items. For example, a database with the value of \$100,000 will be prioritized over a mail server with the value of only \$10,000.

### **The Role that Stakeholders Play in the Security Policy Development Process**

In the security policy development process or the security policy life cycle, the stakeholders include the executive management, security teams, legal counsel, human resources, information technology staff, and general users. Executive management initializes the development process and approves the policy along its lifetime. Security and the information technology team provide expertise and technical requirements while the legal and human resources teams make sure the policy complies to the laws and regulations of the organization. Lastly, the daily operations of all employees influence the implementation, adherence, and feedback for the effectiveness of the policy.

### **Importance of Continuous Monitoring in Maintaining an Effective Security Policy**

Continuous monitoring is important in maintaining an effective policy because it makes sure that the policy and the controls that it sets are working as intended. You could monitor the security controls and procedures that a policy enforced, then you can see the gaps or vulnerabilities that the controls or procedures may have missed due to misconfigurations or faults in technicality and respond accordingly. This is especially true since threats and technologies are constantly evolving and changing. Monitoring and reporting also ensures that the policy controls are working and following regulations. Therefore, monitoring is important to identify security policies that are working well and security policies that are not working so well to refine and update the policies to make them better.

## **Apply the Security Policy Roadmap to a Scenario**

### **Asset Identification**

The assets I would prioritize in a financial institution are personally identifiable information of the customers, transactional data, financial systems data, proprietary algorithms, and system access credentials, including the physical assets that hold the collection of these groups of information. These information assets are important keeping operations going, stabilizing financial information, and complying to rules and regulations. For example, if a financial institution were to leave social security numbers, they would experience a huge impact on customer trust and experience severe regulatory fines. Malicious actors could also use that information to access accounts and steal the finances of innocent people.

I would determine their value by using common methods used by private sectors, who are free to develop classification systems that best suites their organization. They commonly use legally protected, confidential, internal use, and public classifications. Protected classified information assets is data protected by law. Financial account numbers and social security numbers example of this. Confidentially classified information is information essential to the mission of the organization. Proprietary algorithms that provide key strategies of the business would be an example of a confidentially classified asset. Following that we have internally used classified information which is key for doing ordinary business operations. Examples of this would be policy documents and employee lists. Lastly, we would have public information that is information intended to be open to the public. Therefore, I would only prioritize protected and confidential information in a financial institution because they have the largest risks associated with them.

### **Threat and Vulnerability Analysis**

Three potential threats specific to the financial sector are ransomware, third-party attacks, and phishing attacks. Ransomware is software that is used as extortion for money from the organization by encrypting or blocking access to applications or files on the system until an amount of money is paid. Third-party attacks are when financial institutions use third-party vendor services where those vendors get attacked in which data is accessed, and the financial institution is compromised. Phishing attacks are social engineering attacks to make fake sites look legitimate to make fraudulent transfers, take over accounts, take login credentials, and more. This type of attack is especially effective these days due to AI making these sites look more believable.

I would determine the likelihood of these threats by looking at historical data, evaluating what and who these types of threats target and how rewarding these attacks are when successful, and assessing effectiveness of existing security controls in preventing these types of attacks. I would evaluate the impact of these threats by identifying the value of what these threats target and quantifying the potential consequences or financial loss or fines on a successful attack.

## **Control Selection**

For ransomware, one security control measure would be to enforce multi-factor authentication and least privilege for all systems and applications. This is an effective and cost-effective control as prevents lateral movement in the system and further compromises. For third-party vendor attacks, I would force contracts to make sure that third-party vendors are assessed on their security and enforce their measures. For phishing attacks, I would perform mandatory and consistent training to spread of awareness of social engineering tactics, and making sure that up-to-date phishing attacks are known, simulated, and communicated to customers and employees.

## **Communication and Implementation**

Describe how you would ensure that all employees understand and comply with the new security policy.

I would use the key tasks of publication to ensure that all employees understand and comply with the new security policy. These tasks involve communication, dissemination, and education. Communication involves delivering the message that the created policy is important to the organization where different styles of leadership can be effective. Disseminating the policy means making the policy accessible and available by placing the policy in an accessible place and distributing it widely for the audience considering no confidential information is leaked. Lastly, education involves building a culture of education and training for the organization. The goal of education is to raise awareness of the policy and to give each person a connection to the objectives of the policy.

### **Reflect on the Policy Development Process**

The following reflects on the overall process of developing a security policy, as described in the document. The following are the challenges I would anticipate facing when developing and implementing policies in real-world organizations and how I would you address those challenges.

The first challenge in developing a security policy is creating a policy that does not hinder the productivity of the organization. For example, if employees had to comply remembering a 20-character password that changes every 30 days, that would significantly hinder productivity as employees would be spending time remembering or fetching that password rather than working on an important project. To tackle this challenge, I would consider controls that fit the level of risk associated with the data or asset. For example, a low-privileged employee account would have a softer policy compared to a high-privileged employee account.

The second challenge would be to get continuous support from executive management or top leadership which ensures the policy receives the necessary funding and enforcement to comply to the policy throughout the entire organization. To address this challenge, I would use effective communication by using business-related terms to tailor my language to executive management and get support or approval from them. For example, I would communicate the business impact of a “\$10 million regulatory fine with 5 weeks in operational down time” compared to “injection of data SQL data manipulation language”.

The final challenge I see in security policy development is keeping the policy up to date with ever changing threats and technology. Technology and its compliance and regulation is growing at a very fast rate and a policy that is not being updated with these changes are not going to be effective or not going to include effective security measures to deal with threats or vulnerabilities. To tackle this problem, I would do a quarterly review for developed policies and update the policy where it has weakness or ultimately fails.